

漏洞报告 VULN-07: SSTI模板注入

漏洞类型: SSTI模板注入

测试小组: 天亮了吗

被测小组: 天亮了吗

测试时间: 2026-08-26

测试环境: 本机 localhost / 127.0.0.1:5001

测试账号: 课程测试账号, 未使用真实个人密码

1. 基本信息

本报告针对阶段二任务7, 仅在授权的本机课程靶场中完成。

2. 漏洞位置

URL/接口: /、/login、/register 可见输入点审计

请求方法: GET/POST/DELETE (按接口实际方法)

关键参数: username、password、filename、file、csrf_token (按任务适用)

所属功能: 模板渲染

3. 正常请求

先使用正常账号和合法参数完成对应功能, 再仅修改一个测试参数。请求记录和页面证据见附件目录。

正常请求示例: 在本机浏览器访问对应页面, 提交课程测试账号或合法文件; 不包含真实密码、Cookie 或 Token。

4. 漏洞复现步骤

1. 启动本机网盘并登录课程测试账号。
2. 按任务说明构造单一无害测试参数。
3. 发送请求并记录状态码、页面、文件或会话变化。
4. 使用修复后的同一参数再次验证。

5. 攻击效果或异常现象

发送 `name={{7*7}}` 后页面未出现49; 未发现用户输入作为模板执行的输入点。

6. 漏洞原因分析

未发现 `render_template_string` 或等价动态模板调用。

7. 影响范围

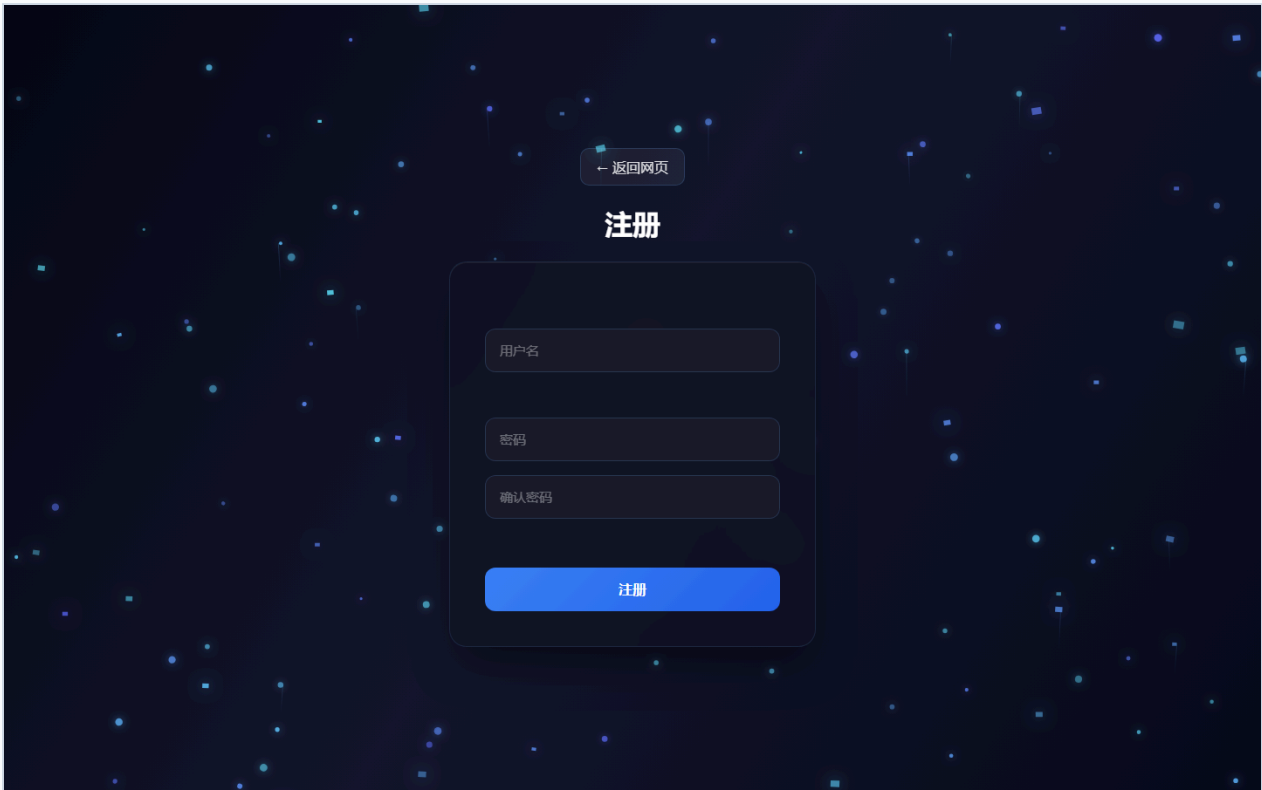
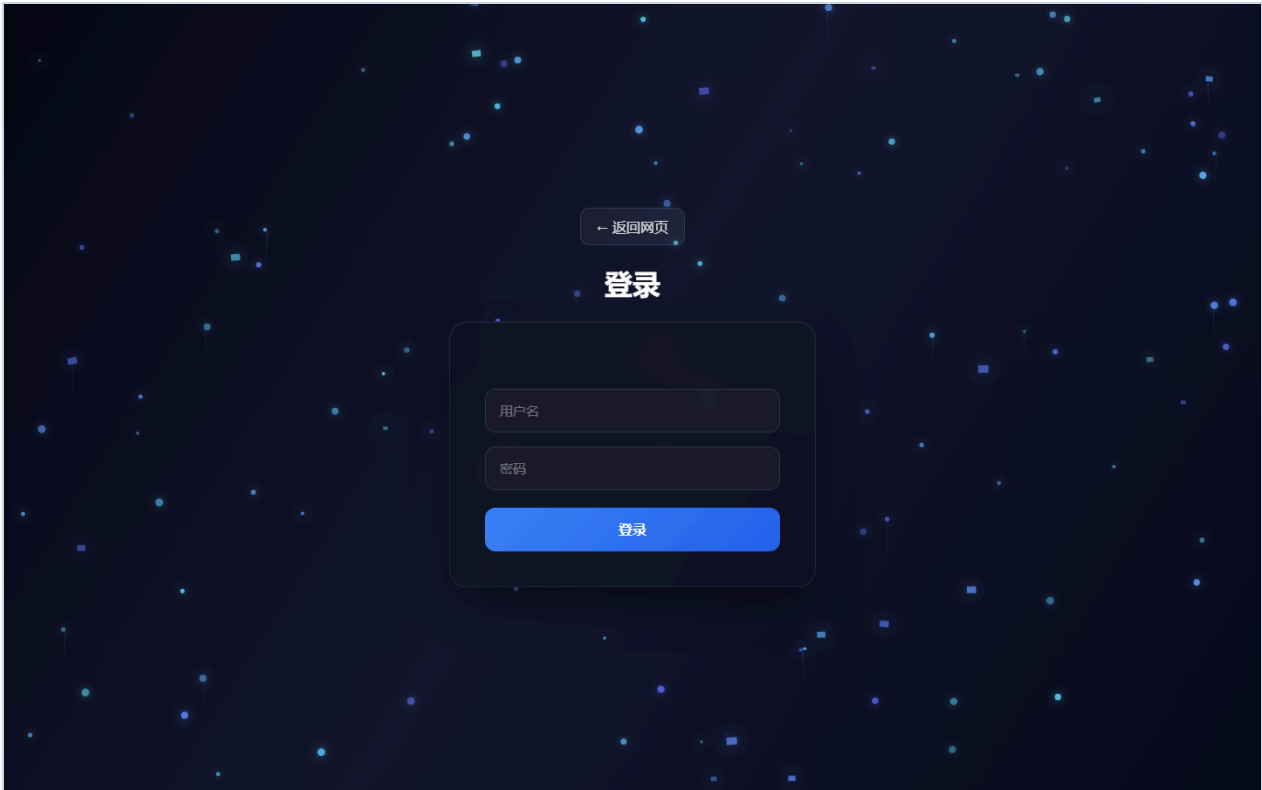
影响范围限于本机课程靶场及测试账号；不得外推为公网系统影响。具体后果取决于接口是否需要登录及资源归属。

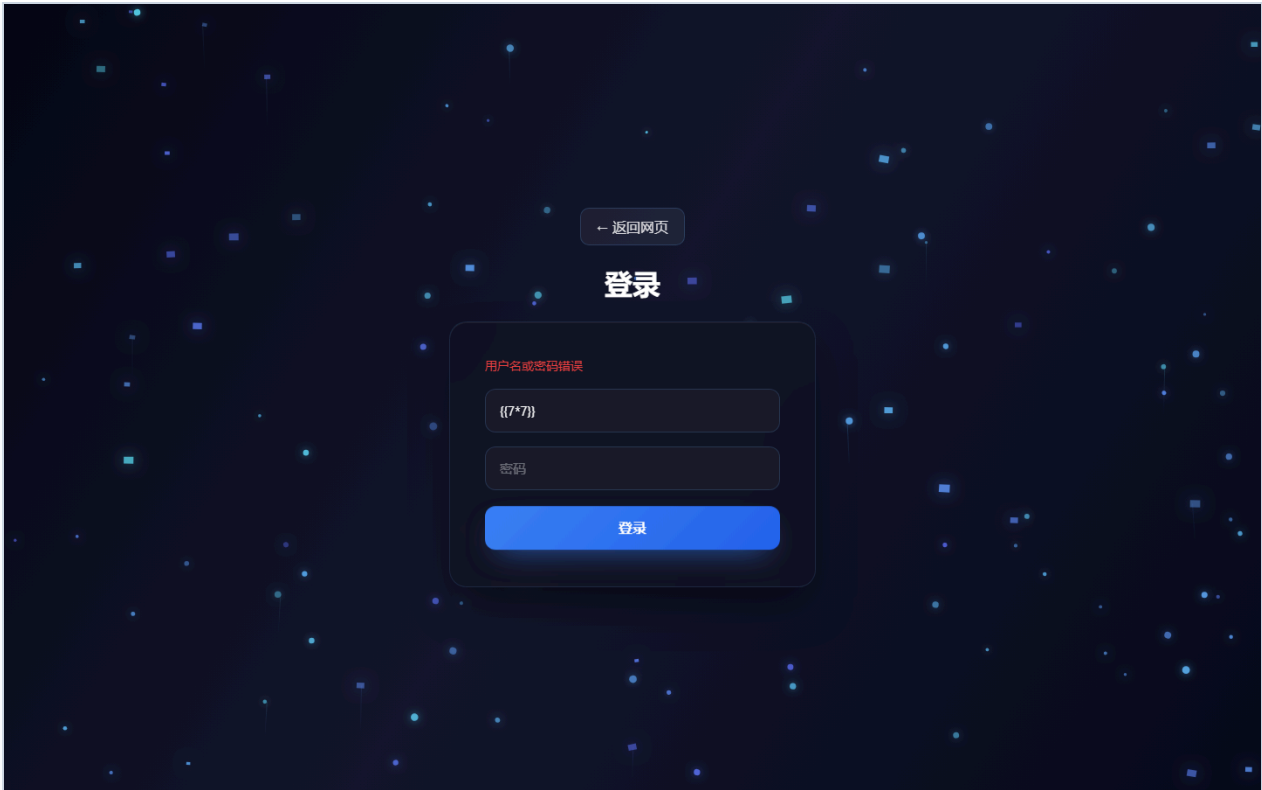
8. 修复建议

用户输入只能作为固定模板变量；禁止动态拼接模板。

9. 附件清单







修复代码截图（实际源文件与行号）

任务 07 修复代码证据

gets.py:150-180

```
150         "size": stat.st_size,
151         "updated_at": stat.st_mtime,
152     }
153 )
154 return files
155
156
157 @app.get("/")
158 def index():
159     return render_template("webpage.html")
160
161
162 @app.get("/login")
163 def login_page():
164     csrf_token()
165     return render_template("login.html")
166
167
168 @app.post("/login")
169 @csrf_protected
170 def login_post():
171     username = request.form.get("username", "").strip()
172     password = request.form.get("password", "")
173     result = _login(username, password, as_api=False)
174     if isinstance(result, tuple) and len(result) == 2 and isinstance(result[1], int) and result[1] >= 400:
175         return render_template("login.html", error=result[0], username=username), result[1]
176     return result
177
178
179 def _login(username, password, as_api=True):
180     if not username or not password:
```